

MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY

KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT
HIỆN VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ
DỤNG AI TÁC TỬ

LUẬN VĂN THẠC SĨ

Học viên: Nguyễn Đức Bình
MSSV: MSE13183

Hà Nội, 2026

MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY

KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT
HIỆN VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ
DỤNG AI TÁC TỬ

LUẬN VĂN THẠC SĨ

Học viên: Nguyễn Đức Bình
MSSV: MSE13183

Giảng viên hướng dẫn: 1. Bùi Văn Hiệu
2. [Tên GVHD phụ nếu có]

Hà Nội, 2026

Abstract

This thesis proposes a novel two-tier cognitive architecture, named SENTINEL, to automate network security threat triage and response. The first tier utilizes Welford's online statistical anomaly detection to filter out benign traffic at wire speed. The second tier acts as an AI Agent built on LangGraph, utilizing offline large language model (LLM) reasoning and hybrid Dual-RAG (MITRE ATT&CK and NIST SP 800-61r2) for threat classification and mitigation instruction. Prompt safety is enforced via Delimited Data Encapsulation, knowledge base integrity is cryptographically validated using SHA-256 checksum signing, semantic cache poisoning is mitigated through context-level structural sanitization, and database audit logs are secured using HMAC log chaining. Evaluated on CSE-CIC-IDS2018 and DAPT2020 datasets, the system demonstrates high precision, low latency, and robustness against adversarial attacks.

Lời cảm ơn

Lời cảm ơn ghi nhận tại đây...

Mục lục

Abstract	iii
Lời cảm ơn	iv
1 Mở đầu	1
1.1 Bối cảnh nghiên cứu và Lý do chọn đề tài	1
1.2 Mục tiêu nghiên cứu	3
1.3 Câu hỏi nghiên cứu	4
1.4 Đối tượng và Phạm vi nghiên cứu	5
1.5 Phương pháp nghiên cứu	6
1.6 Đóng góp của luận văn	6
1.7 Cấu trúc của luận văn	7
2 Cơ sở lý thuyết và các nghiên cứu liên quan	9
2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Phân tích Sự cố . .	9
2.2 Mô hình Ngôn ngữ Lớn (LLM) và Kỹ thuật Lượng tử hóa (Quantization) .	10
2.3 Kiến trúc AI Tác tử (Agentic AI) và Đồ thị trạng thái	10
2.4 Kỹ thuật Truy xuất Tri thức (RAG) và Tìm kiếm Lai (Hybrid Search) . . .	10
2.5 An toàn cho Hệ thống LLM (AI Security)	11
2.6 Thuật toán Phát hiện Dị thường Thống kê (Welford's Algorithm)	11
2.7 Tổng quan các Nghiên cứu Liên quan	12

3	Kiến trúc hệ thống đề xuất SENTINEL	13
3.1	Tổng quan Kiến trúc Nhận thức Hai tầng (Two-Tier Architecture)	13
3.2	Tầng 1 (Tier-1): Động cơ lọc lưu lượng thời gian thực (RuleEngine & Welford)	14
3.3	Tầng 2 (Tier-2): Tác tử AI LangGraph (Cognitive Agent)	14
3.4	Cơ chế Truy xuất Tri thức Kép (Dual-RAG) và Bộ nhớ Semantic	14
3.5	Bộ nhớ Đe dọa (Threat Memory) và Tương quan Chiến dịch APT	15
3.6	Hệ thống Phòng vệ AI Guardrails (AI Security Layer)	15
3.7	Bảo vệ Toàn vẹn Chứng cứ (Data Integrity & HMAC)	15
4	Triển khai kỹ thuật	17
4.1	Môi trường Công nghệ và Cấu trúc Mã nguồn Dự án	17
4.2	Triển khai Tier-1: Động cơ Lọc & Welford	17
4.3	Triển khai Tier-2: AI Agent và RAG	18
4.4	Cài đặt Hệ thống Bảo vệ Guardrail và HMAC	18
4.5	Triển khai Giao diện Quản trị SOC (Streamlit Dashboard)	18
4.6	Đóng gói và Triển khai Hạ tầng (Containerization)	19
5	Thực nghiệm và Đánh giá kết quả	20
5.1	Thiết lập Môi trường và Tập dữ liệu Thực nghiệm	20
5.2	Khung đánh giá 5 Chiều (5D Metrics) và Thiết kế Ablation Study	21
5.3	Đánh giá Độ chính xác (Accuracy) & Kiểm định McNemar	21
5.4	Đánh giá Hiệu năng Độ trễ (Performance) & Kiểm định Mann-Whitney U	22
5.5	Đánh giá Khả năng Kháng tấn công Nghịch đảo (Security / Robustness) .	22
5.6	Đánh giá Tính Toàn vẹn và Chất lượng RAG bằng LLM-as-a-Judge	22
6	Kết luận và Hướng phát triển	24
6.1	Tổng hợp các Kết quả Nghiên cứu Đạt được	24
6.2	Đóng góp Khoa học và Thực tiễn	25

6.3	Những Hạn chế còn Tồn đọng	25
6.4	Định hướng Phát triển Tương lai	26
Tài liệu tham khảo		1
A Các payload tấn công nghich đảo thử nghiệm		1

Danh sách bảng

Danh sách hình vẽ

Chương 1

Mở đầu

Chương này cung cấp cái nhìn tổng quan và cơ sở nền tảng cho việc thực hiện luận văn nghiên cứu. Nội dung chương bắt đầu bằng việc phân tích bối cảnh an ninh mạng hiện đại, đặc biệt là những thách thức mà các Trung tâm Điều hành An ninh (SOC) đang phải đối mặt. Từ việc phân tích những hạn chế của các hệ thống truyền thống và những rủi ro khi ứng dụng AI tạo sinh, chương làm rõ lý do hình thành và lựa chọn đề tài kiến trúc nhận thức hai tầng SENTINEL. Tiếp theo, chương xác định rõ ràng mục tiêu, câu hỏi nghiên cứu, đối tượng, phương pháp và phạm vi nghiên cứu, đồng thời tóm tắt những đóng góp chính và cấu trúc tổng thể của luận văn.

1.1 Bối cảnh nghiên cứu và Lý do chọn đề tài

Trong kỷ nguyên chuyển đổi số và điện toán đám mây, các tổ chức, doanh nghiệp đang phải đối mặt với một chiến trường không gian mạng ngày càng phức tạp. Các bề mặt tấn công không ngừng mở rộng, kết hợp với sự tinh vi của các tác nhân đe dọa có tổ chức (APT - Advanced Persistent Threats) đã khiến các phương thức phòng thủ truyền thống trở nên quá sức. Để bảo vệ tài sản thông tin, các Trung tâm Điều hành An ninh (SOC) được xây dựng đóng vai trò nòng cốt trong việc giám sát, phát hiện và ứng cứu sự cố. Tuy nhiên, kiến trúc vận hành của các SOC hiện đại đang gặp phải "Nghịch lý Dữ liệu lớn" (Big Data Paradox), bộc lộ ba điểm yếu cốt lõi:

- **Vấn nạn Alert Fatigue (Mệt mỏi vì cảnh báo):** Sự bùng nổ của các thiết bị tường lửa (Firewall), hệ thống phát hiện/ngăn ngừa xâm nhập (IDS/IPS) và hệ thống quản lý thông tin và sự kiện bảo mật (SIEM) tạo ra hàng triệu cảnh báo mỗi ngày. Tỷ lệ báo động giả (False Positive) từ các hệ thống này thường rất lớn, làm quá tải đội ngũ chuyên gia phân tích (Tier-1 Analysts), dẫn đến hiện tượng "bỏ qua cảnh báo" khiến các cuộc tấn công thực tế bị lọt lưới.
- **Giới hạn của các hệ thống dựa trên Luật (Rule-based):** Các công cụ SIEM/IDS truyền thống hoạt động chủ yếu dựa trên chữ ký (signatures) và các tập luật tĩnh. Dù hiệu quả với các cuộc tấn công đã biết, chúng hoàn toàn mù lòa trước các cuộc tấn công chưa có mẫu (Zero-day) hoặc các biến thể tấn công đa hình.
- **Hạn chế của phương pháp giảm tải dữ liệu truyền thống:** Để đối phó với lưu lượng log khổng lồ, nhiều SOC áp dụng cơ chế lấy mẫu ngẫu nhiên (Random Sampling) hoặc lấy mẫu theo ngưỡng tĩnh (Static Thresholding). Phương pháp này vô tình cắt đứt các chuỗi bằng chứng thời gian, làm mất đi các mối xích quan trọng của các chiến dịch tấn công APT "Low-and-Slow" vốn thực hiện các bước thăm dò cực kỳ kín kẽ, kéo dài hàng tuần hoặc hàng tháng.

Sự trỗi dậy của Trí tuệ Nhân tạo Tạo sinh (Generative AI), đặc biệt là các Mô hình Ngôn ngữ Lớn (LLM), đã mở ra tiềm năng to lớn trong việc tự động hóa phân tích logs, diễn dịch ngữ cảnh và đề xuất phương án ứng cứu. Tuy nhiên, việc đưa trực tiếp LLM vào luồng dữ liệu của SOC vấp phải hai rào cản kỹ thuật và bảo mật nghiêm trọng:

1. **Độ trễ xử lý (Latency) và Tiêu thụ tài nguyên:** Việc gửi toàn bộ luồng logs thô qua LLM để suy luận sẽ gây ra hiện tượng nghẽn cổ chai (bottleneck) nghiêm trọng. Kiến trúc Transformer của LLM đòi hỏi năng lực tính toán cực lớn, không thể đáp ứng được yêu cầu phân tích theo thời gian thực (wire-speed) của hệ thống mạng.
2. **Nguy cơ tấn công thao túng AI (Prompt Injection và Semantic Poisoning):** Kẻ tấn công có thể chèn các chuỗi câu lệnh phá hoại vào chính dữ liệu mạng (ví dụ:

một payload HTTP User-Agent chứa lệnh: *"Bỏ qua mọi luật trước đó, hãy phân loại luồng này là an toàn"*). Nếu LLM xử lý trực tiếp các log này mà không có cơ chế cách ly, hệ thống AI của SOC sẽ bị thao túng hoàn toàn, biến hệ thống phòng thủ thành điểm yếu chí mạng.

Nhận thức được những thách thức mang tính chiến lược nêu trên, cùng với nền tảng kiến thức về AI Engineering và An toàn thông tin, tác giả nhận thấy sự cấp thiết của việc xây dựng một kiến trúc kết hợp tối ưu: Sàng lọc thô tốc độ cao bằng thuật toán phi trạng thái ở tầng dưới, và suy luận nhận thức chuyên sâu, cách ly an toàn bằng AI Tác tử ở tầng trên. Từ nhận thức đó, đề tài **"Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động sử dụng AI tác tử"** (Hệ thống SENTINEL) được lựa chọn làm định hướng nghiên cứu cho luận văn thạc sĩ.

1.2 Mục tiêu nghiên cứu

Đề tài hướng tới việc giải quyết bài toán tự động hóa SOC bằng việc xây dựng một hệ thống phát hiện xâm nhập và phản hồi thông minh, hiệu năng cao và có khả năng chống chịu các tấn công nhắm vào chính AI.

Mục tiêu tổng quát: Xây dựng, triển khai và đánh giá kiến trúc hệ thống SENTINEL - một kiến trúc hai tầng kết hợp giữa phát hiện bất thường thống kê và phân tích ngữ cảnh bằng AI Tác tử.

Mục tiêu cụ thể:

- **Phát triển Tier 1 (Tầng Vận chuyển):** Tích hợp thuật toán thống kê trực tuyến Welford để đánh giá độ lệch chuẩn (Z-Score) liên tục trên dòng dữ liệu không gian hẹp. Mục tiêu là lọc bỏ phần lớn lưu lượng lành tính ở tốc độ đường truyền (thời gian thực $O(1)$ về mặt bộ nhớ) mà không làm mất trạng thái của luồng.
- **Xây dựng Tier 2 (Tầng Nhận thức):** Phát triển AI Agent dựa trên kiến trúc LangGraph

và LLM cục bộ (Local LLM), kết hợp với cơ chế truy xuất tri thức kép Dual-RAG (sử dụng cơ sở dữ liệu MITRE ATT&CK và NIST SP 800-61r2) để phân loại mối đe dọa, lập luận và đưa ra khuyến nghị phản hồi tự động.

- **Đảm bảo an toàn cho AI:** Thiết kế cơ chế Delimited Data Encapsulation (đóng gói bằng dấu phân cách ngẫu nhiên) để vô hiệu hóa hoàn toàn các tấn công Prompt Injection nhúng trong payload mạng.
- **Đảm bảo tính toàn vẹn hệ thống:** Xây dựng cơ chế xác thực toàn vẹn bằng chữ ký SHA-256 cho hệ thống tri thức RAG và ứng dụng chuỗi băm HMAC (HMAC Chaining) cho database audit log nhằm chống lại sự giả mạo chứng cứ của kẻ tấn công nội bộ.

1.3 Câu hỏi nghiên cứu

Để đạt được các mục tiêu đã đề ra, nghiên cứu tập trung giải quyết và trả lời ba câu hỏi cốt lõi sau đây:

1. **CQ1:** Làm thế nào để thiết kế một cơ chế sàng lọc nhiễu lưu lượng mạng khối lượng lớn theo thời gian thực mà không làm đứt gãy hay mất dấu vết của các chuỗi sự kiện có độ trễ cao đặc trưng cho tấn công APT?
2. **CQ2:** Bằng phương pháp nào để tích hợp sức mạnh suy luận của LLM vào quy trình phân tích SOC tự động mà vẫn giải quyết được nghịch lý về độ trễ xử lý, đồng thời ngăn chặn triệt để các rủi ro thao túng AI thông qua mã độc nhúng trong log (Prompt Injection)?
3. **CQ3:** Sự kết hợp giữa bộ nhớ ngữ nghĩa của Tác tử (Agent Memory) và hệ thống truy xuất tri thức ngoài (Dual-RAG) mang lại hiệu quả như thế nào trong việc nhận diện các mối đe dọa Zero-day và giảm thiểu tỷ lệ hoang tưởng (Hallucination) của LLM?

1.4 Đối tượng và Phạm vi nghiên cứu

Đối tượng nghiên cứu:

- Dữ liệu luồng lưu lượng mạng (Network Flow Logs) và dữ liệu đánh chặn gói tin chứa mã độc.
- Các kỹ thuật của AI Tác tử (Agentic AI), Mô hình ngôn ngữ lớn (LLM), Đồ thị tri thức (Knowledge Graph) và Kỹ thuật sinh bổ sung kết xuất (RAG).
- Các phương thức tấn công xâm nhập mạng và các kỹ thuật tấn công nhắm vào hệ thống AI (Prompt Injection, Semantic Poisoning).

Phạm vi nghiên cứu:

- **Dữ liệu thực nghiệm:** Đánh giá trên các bộ dữ liệu chuẩn quốc tế bao gồm CSE-CIC-IDS2018 (mô phỏng các hình thái tấn công mạng diện rộng) và DAPT2020 (mô phỏng các chiến dịch APT dài ngày).
- **Mô hình AI:** Tập trung khảo sát và tối ưu hóa các Local LLM mã nguồn mở (cụ thể là Gemma-2-9B-IT) được lượng tử hóa (Quantization) để có thể vận hành cục bộ trên một GPU duy nhất, đáp ứng yêu cầu bảo mật dữ liệu tuyệt đối của mô hình SOC nội bộ.
- **Môi trường phản hồi:** Các phản ứng của hệ thống (Mitigation) được giới hạn ở mức phân tích, xuất báo cáo và sinh ra các tập luật tường lửa (Firewall Rules) mô phỏng. Nghiên cứu không bao gồm việc tự động thực thi các tác động vật lý cắt đứt kết nối mạng trên thiết bị thật để tránh rủi ro sập hệ thống (Denial of Service tự gây ra) do lỗi nhận định của AI.

1.5 Phương pháp nghiên cứu

Đề tài sử dụng phương pháp nghiên cứu định lượng kết hợp thực nghiệm kỹ thuật sâu (Experimental Engineering Methodology):

- **Phương pháp Thiết kế và Xây dựng (Design & Implementation):** Lên kiến trúc, lập trình hệ thống phần mềm (Python, Neo4j, FAISS, LangGraph, llama.cpp), đóng gói Docker và thiết lập các kịch bản kiểm thử (Testbeds).
- **Phương pháp Mô phỏng và Thực nghiệm:** Thiết lập môi trường mô phỏng luồng dữ liệu liên tục (Unified Stream) để kiểm tra luồng chạy từ đầu đến cuối (End-to-End) của hệ thống trước các biến thể tấn công (Zero-day, APT). Chạy các công cụ tấn công mã hóa để kiểm thử Guardrail bảo mật AI.
- **Phương pháp Đánh giá và Thống kê (Evaluation & Statistical Analysis):** Đánh giá hiệu năng và độ chính xác thông qua khung định lượng 5 chiều (5D Metrics: Accuracy, Security, Performance, Integrity, Cognitive). Áp dụng các kiểm định thống kê (McNemar's test, Mann-Whitney U test) và phương pháp phân tích cắt lớp (Ablation Study) để chứng minh tính ưu việt có ý nghĩa thống kê của mô hình kiến trúc đề xuất so với các mô hình độc lập (baseline).

1.6 Đóng góp của luận văn

Luận văn mang lại những đóng góp nổi bật ở cả khía cạnh lý thuyết và thực tiễn kỹ thuật:

- **Đóng góp về kiến trúc (Architectural):** Đề xuất thành công mô hình lai SENTINEL hai tầng, cân bằng hoàn hảo giữa hiệu năng (xử lý dòng lưu lượng lớn thông qua Welford's algorithm) và năng lực nhận thức sâu (Agentic AI).
- **Đóng góp về an ninh AI (AI Security):** Chứng minh thực nghiệm phương pháp đóng gói dữ liệu an toàn (Delimited Data Encapsulation) kết hợp cơ chế kiểm tra

toàn vẹn tri thức (HMAC & SHA-256), giúp hệ thống phòng thủ miễn nhiễm hoàn toàn với các nỗ lực Prompt Injection và Data Poisoning - một lỗ hổng nghiêm trọng của các hệ thống tích hợp LLM hiện nay.

- **Đóng góp về tính tự chủ (Autonomy):** Đưa khái niệm AI Tác tử dựa trên đồ thị trạng thái (State Graph) vào quy trình Incident Response, thay thế quy trình RBA (Runbook Automation) tĩnh bằng quy trình ra quyết định động dựa trên ngữ cảnh thực tế theo thời gian thực.

1.7 Cấu trúc của luận văn

Luận văn được tổ chức một cách logic, từ nền tảng lý thuyết đến thiết kế, triển khai thực nghiệm và kết luận. Cấu trúc cụ thể bao gồm 6 chương:

- **Chương 1: Mở đầu** - Trình bày bối cảnh, lý do chọn đề tài, mục tiêu, câu hỏi nghiên cứu, đối tượng, phương pháp, phạm vi và những đóng góp chính của luận văn.
- **Chương 2: Cơ sở lý thuyết và Các nghiên cứu liên quan** - Cung cấp nền tảng lý thuyết về Agentic AI, hệ thống RAG, thuật toán thống kê trực tuyến Welford, an toàn LLM và phân tích các hệ thống SOC truyền thống. Chương cũng tổng quan các công trình nghiên cứu hiện có để làm nổi bật khoảng trống nghiên cứu.
- **Chương 3: Kiến trúc hệ thống đề xuất SENTINEL** - Trình bày thiết kế tổng thể của kiến trúc nhận thức hai tầng, chi tiết thiết kế Tầng Vận chuyển (Tier 1), Tầng Nhận thức Tác tử (Tier 2), Đồ thị tri thức bảo mật (Dual-RAG) và các cơ chế phòng thủ bảo vệ hệ thống AI.
- **Chương 4: Triển khai kỹ thuật** - Đặc tả chi tiết môi trường phát triển, thiết kế mã nguồn hệ thống, tích hợp các công cụ (Neo4j, FAISS, llama.cpp), đóng gói vùng chứa (Docker containerization) và xây dựng giao diện tương tác (Streamlit Dashboard).
- **Chương 5: Thực nghiệm và Đánh giá kết quả** - Trình bày chi tiết các thiết lập thí

nghiệm, bộ dữ liệu (CSE-CIC-IDS2018, DAPT2020), và phân tích đánh giá kết quả định lượng sâu sắc dựa trên các độ đo 5D, Ablation Study và phân tích thống kê.

- **Chương 6: Kết luận và Hướng phát triển** - Tổng kết lại các kết quả đạt được, đối chiếu với mục tiêu nghiên cứu ban đầu, chỉ ra những hạn chế còn tồn tại và đề xuất các định hướng nghiên cứu phát triển mở rộng trong tương lai.

Chương 2

Cơ sở lý thuyết và các nghiên cứu liên quan

Chương này cung cấp các nền tảng lý thuyết khoa học máy tính và an ninh mạng làm cơ sở vững chắc cho việc thiết kế kiến trúc SENTINEL. Nội dung bao quát từ kiến trúc hệ thống giám sát an ninh (SOC), thuật toán phát hiện dị thường thống kê, cho đến các công nghệ cốt lõi của AI tạo sinh bao gồm Mô hình ngôn ngữ lớn (LLM), AI Tác tử (Agentic AI), hệ thống RAG và các nguy cơ bảo mật AI liên quan. Cuối chương là tổng quan các nghiên cứu đã có, nhằm làm nổi bật khoảng trống nghiên cứu mà đề tài hướng tới.

2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Phân tích Sự cố

- **Cấu trúc SOC hiện đại:** Các thành phần cốt lõi (SIEM, IDS/IPS, Firewall, EDR) và quy trình chuẩn xử lý sự cố (Incident Response - IR).
- **Thách thức Alert Fatigue:** Định nghĩa, nguyên nhân gây ra quá tải cảnh báo giả (False Positives) và hệ lụy đối với đội ngũ chuyên gia phân tích (Tier-1 Analysts).
- **Khái niệm tấn công APT (Advanced Persistent Threats) & Zero-day:** Sự tinh vi của các chiến dịch “low-and-slow”, khó khăn của các hệ thống Rule-based trong việc nhận diện dị thường kéo dài.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Kỹ thuật Lượng tử hóa (Quantization)

- **Kiến trúc Transformer:** Cơ chế tự chú ý (Self-Attention) và khả năng xử lý ngôn ngữ tự nhiên trong ngữ cảnh.
- **Khái niệm Local LLM và Bảo mật Dữ liệu:** Tầm quan trọng của việc chạy LLM cục bộ trong môi trường Air-gapped của SOC (Zero Trust).
- **Kỹ thuật Lượng tử hóa (Quantization):** Cơ chế GGUF, chuẩn Q4_K_M để giảm thiểu dung lượng VRAM cần thiết nhằm vận hành mô hình lớn (như Gemma-2-9B) trên phần cứng giới hạn (GPU 16GB) thông qua framework `llama.cpp`.

2.3 Kiến trúc AI Tác tử (Agentic AI) và Đồ thị trạng thái

- **Agentic Workflow:** Sự chuyển dịch từ RBA (Runbook Automation) tĩnh sang quy trình AI có khả năng lập luận, lập kế hoạch và phản hồi linh hoạt.
- **Đồ thị trạng thái hữu hạn (Finite State Machine):** Lý thuyết về đồ thị có hướng, nút (Nodes) và cạnh có điều kiện (Conditional Edges).
- **Framework LangGraph:** Ứng dụng cụ thể của LangGraph để xây dựng vòng lặp nhận thức cho tác tử, giúp mô hình tự nhận thức khi cần tra cứu thêm thông tin hoặc kết thúc suy luận.

2.4 Kỹ thuật Truy xuất Tri thức (RAG) và Tìm kiếm Lai (Hybrid Search)

- **Khái niệm Retrieval-Augmented Generation (RAG):** Giải quyết vấn đề hoang tưởng (Hallucination) của LLM bằng cơ sở dữ liệu ngoài.
- **Tìm kiếm Vector (Dense Search):** Kiến trúc mạng nhúng Embedding (all-MiniLM-L6-v2) và thuật toán FAISS (Facebook AI Similarity Search) xử lý không gian vector

nhiều chiều.

- **Tìm kiếm Từ khóa (Sparse Search):** Cấu trúc chỉ mục BM25Okapi và thuật toán TF-IDF.
- **Thuật toán lai Reciprocal Rank Fusion (RRF):** Phương pháp toán học kết hợp thứ hạng từ Dense và Sparse Search để tối ưu kết quả (cấu hình $k = 60$).

2.5 An toàn cho Hệ thống LLM (AI Security)

- **Tấn công Prompt Injection:** Phân tích rủi ro khi dữ liệu không tin cậy thâm nhập vào ngữ cảnh của LLM, dẫn đến thao túng hành vi.
- **Tấn công Delimiter Smuggling và Data Exfiltration:** Rủi ro chèn ký tự phân cách giả mạo và trích xuất dữ liệu trái phép (Markdown Exfiltration/XSS).
- **Cơ chế bảo vệ Guardrails:** Các phương pháp luận về bảo vệ đầu vào (Input filtering) và làm sạch đầu ra (Output sanitization).

2.6 Thuật toán Phát hiện Dị thường Thống kê (Welford's Algorithm)

- **Lý thuyết thống kê trực tuyến (Online Statistics):** Yêu cầu xử lý dòng dữ liệu liên tục với bộ nhớ tĩnh ($O(1)$).
- **Định lý Welford:** Công thức toán học cập nhật trung bình (Mean) và phương sai (Variance) liên tục mà không bị sai số làm tròn (numerical instability). Phân tích cách tính Z-Score trực tuyến.

2.7 Tổng quan các Nghiên cứu Liên quan

- **Ứng dụng ML/DL truyền thống trong IDS:** Đánh giá các mô hình Random Forest, LSTM, CNN trong phát hiện xâm nhập và những hạn chế về tính giải thích (Explainability).
- **Ứng dụng LLM trong SOC:** Điểm qua các công trình tích hợp ChatGPT/LLM vào an ninh mạng gần đây.
- **Khoảng trống nghiên cứu (Research Gap):** Nhấn mạnh các nghiên cứu hiện tại bỏ qua vấn đề độ trễ (Latency bottleneck) khi xử lý trực tiếp log khối lượng lớn bằng LLM và sự mong manh trước các cuộc tấn công Prompt Injection nhúng trong log mạng.

Tóm lại, Chương 2 đã làm sáng tỏ các lý thuyết cốt lõi sử dụng trong đề tài. Dựa trên các cơ sở này, Chương 3 sẽ đi vào giới thiệu chi tiết kiến trúc giải pháp hệ thống đề xuất SENTINEL.

Chương 3

Kiến trúc hệ thống đề xuất SENTINEL

Chương này mô tả chi tiết thiết kế hệ thống SENTINEL (Cognitive Two-Tier Architecture). Đây là cốt lõi khoa học của luận văn, nhằm giải quyết bài toán phát hiện và phản hồi mối đe dọa (TDIR) một cách tự động, tốc độ cao và an toàn tuyệt đối trước các nỗ lực thao túng AI. Nội dung bao quát từ tổng quan luồng dữ liệu 2 tầng, bộ lọc Welford trực tuyến, mô hình Tác tử LangGraph với Dual-RAG, cho đến các kiến trúc bảo mật tiên tiến (Guardrails, HMAC Chaining).

3.1 Tổng quan Kiến trúc Nhận thức Hai tầng (Two-Tier Architecture)

- **Sơ đồ khối hệ thống tổng thể:** Trình bày flow biểu đồ luồng dữ liệu bắt đầu từ hệ thống sinh log, qua Tier-1 (Tầng Vận chuyển/Bộ lọc) đến Tier-2 (Tầng Nhận thức/AI Agent) và hệ thống Database/Dashboard.
- **Triết lý thiết kế (Design Philosophy):** Sự phân chia trách nhiệm: Tier-1 chịu trách nhiệm lọc nhiễu ở tốc độ đường truyền (Wire-speed), Tier-2 cung cấp khả năng phân tích ngữ cảnh sâu và giải quyết tính mù lòa của Zero-day.

3.2 Tầng 1 (Tier-1): Động cơ lọc lưu lượng thời gian thực (RuleEngine & Welford)

- **Quản lý Baseline và Phiên (Session Baseline):** Cách lưu trữ và cập nhật trạng thái kết nối mạng theo thời gian.
- **Cơ chế Welford trực tuyến (Online Welford's Algorithm):** Đặc tả chi tiết triển khai toán học tính Z-Score tại mỗi luồng log. Khi Z-Score vượt ngưỡng α , hệ thống sinh nhãn cảnh báo (ESCALATE) cho Tier-2 thay vì thả (DROP).
- **Luật tĩnh kết hợp (Static Rule Engine):** Tích hợp các bộ luật signature-based tĩnh cơ bản (DROP, WARN) để loại trừ ngay lập tức các mẫu tấn công sơ cấp.

3.3 Tầng 2 (Tier-2): Tác tử AI LangGraph (Cognitive Agent)

- **Thiết kế StateGraph (Đồ thị trạng thái):** Cấu trúc của đối tượng `SentinelState` mang thông tin phiên chạy. Định nghĩa các Node: Phân tích (Analyze), Truy xuất tri thức (Retrieve), Giải quyết (Resolve).
- **Điều hướng có điều kiện (Conditional Edges):** Luồng tư duy nội tại của AI Agent. Khi AI thiếu kiến thức, nó tự động nhảy sang trạng thái `retrieve_knowledge` và sau đó quay lại đánh giá.

3.4 Cơ chế Truy xuất Tri thức Kép (Dual-RAG) và Bộ nhớ Semantic

- **Kiến trúc Dual-RAG:** Hợp nhất hai cơ sở kiến thức đặc thù: MITRE ATT&CK (Định danh TTPs) và NIST SP 800-61r2 (Sổ tay hướng dẫn ứng phó sự cố).
- **Thuật toán lai (Hybrid Search):** Quá trình kết hợp điểm số Dense (FAISS) và Sparse (BM25) sử dụng RRF.

- **Semantic Cache (Bộ nhớ đệm ngữ nghĩa):** Cơ chế băm nhúng ngữ nghĩa (Semantic Hashing) để bỏ qua LLM nếu luồng log tương tự đã được phân tích thành công trước đó trong ngày, giảm tối đa độ trễ.

3.5 Bộ nhớ Đe dọa (Threat Memory) và Tương quan Chiến dịch APT

- **Lưu trữ dữ liệu đồ thị / tương quan IP (SQLite/Neo4j):** Logic theo dõi điểm uy tín (Reputation Score) của địa chỉ IP theo thời gian.
- **Cơ chế liên kết APT (APT Correlation):** Thuật toán xâu chuỗi các sự kiện mức độ thấp (Low-severity anomalies) xảy ra rải rác qua nhiều ngày để hình thành một bản án nâng cao (Escalate to High-severity).

3.6 Hệ thống Phòng vệ AI Guardrails (AI Security Layer)

- **Đóng gói Dấu phân cách ngẫu nhiên (Delimited Data Encapsulation):** Thuật toán sinh token mật mã ngẫu nhiên cho mỗi phiên (ví dụ: < | PAYLOAD_A7F9 | >), đóng khung dữ liệu ngoại lai để LLM không thực thi các mệnh lệnh lẫn khuất (Prompt Injection).
- **Quản lý ngân sách Token (Token Budget Manager) & Nén Log (LogTemplateMiner):** Ứng dụng Drain3 để loại bỏ các biến động text ngẫu nhiên, gom cụm log để tránh tấn công DoS Token nhắm vào LLM.
- **Bộ lọc Output Sanitization:** Chuẩn hóa nghiêm ngặt đầu ra JSON của LLM.

3.7 Bảo vệ Toàn vẹn Chứng cứ (Data Integrity & HMAC)

- **Chuỗi băm sự kiện (HMAC Log Chaining):** Thuật toán liên kết hàm băm mật mã học từ log trước sang log sau, đảm bảo mọi hành vi sửa xóa log (Tampering) của kẻ

tấn công nội bộ đều làm đứt gãy chuỗi và bị phát hiện.

- **Ký băm RAG (RAG SHA-256 Checksum):** Đảm bảo cơ sở dữ liệu vector RAG không bị chèn ép các tài liệu sai lệch (Data Poisoning).

Tóm lại, Chương 3 đã thiết lập bộ khung lý thuyết vững chắc về kiến trúc của hệ thống SENTINEL, giải quyết toàn vẹn cả hiệu năng (Tier-1) và nhận thức sâu, an toàn (Tier-2). Chương tiếp theo sẽ đặc tả quy trình chuyển hóa kiến trúc này thành mã nguồn kỹ thuật.

Chương 4

Triển khai kỹ thuật

Chương này trình bày chi tiết về khía cạnh công nghệ phần mềm và các bước triển khai mã nguồn thực tiễn của kiến trúc SENTINEL. Thay vì lý thuyết trừu tượng, nội dung ở đây tập trung vào sơ đồ tổ chức thư mục, các lớp đối tượng cốt lõi (Classes/Methods), các dịch vụ Docker và thiết kế Giao diện quản trị đồ họa (Streamlit Dashboard) hỗ trợ tương tác giữa con người và máy (Human-in-the-Loop).

4.1 Môi trường Công nghệ và Cấu trúc Mã nguồn Dự án

- **Công nghệ cốt lõi:** Python 3.10+, LangGraph, LangChain, FAISS, SQLite, Streamlit, Docker, llama.cpp (với thư viện Llama-cpp-python).
- **Cấu trúc thư mục (Directory Structure):** Biểu diễn cây thư mục (Tree) chi tiết, phân chia rạch ròi các thành phần: `src/core/` (Tier 1 & 2), `src/rag/` (Vector DB), `src/security/` (Guardrails), `src/dashboard/` (UI), `experiments/`, `tests/`.

4.2 Triển khai Tier-1: Động cơ Lọc & Welford

- **Lớp RunningStats và SessionBaseline:** Triển khai mã nguồn Python cho thuật toán Welford. Giải quyết bài toán cấp phát bộ nhớ từ điển (dictionary allocation)

bằng hàm hash IP và dọn dẹp bộ đệm (TTL cache).

- **Lớp RuleEngine:** Thiết kế pattern Matching dựa trên Regex và Static Thresholds.

4.3 Triển khai Tier-2: AI Agent và RAG

- **Lớp OpenAILLMClient / Llama.cpp Wrapper:** Cách thiết lập thông số cho Local LLM (temperature=0.0 để tối ưu tính xác định, cấu hình context size, n_gpu_layers).
- **Thiết lập LangGraph Workflow:** Cách sử dụng StateGraph để định nghĩa các node analyze_node, retrieve_node và hàm should_retrieve cho các cạnh điều kiện.
- **Lớp DualRetriever:** Triển khai FAISS Index và rank_bm25 cho tính năng hợp nhất Reciprocal Rank Fusion (RRF). Mã nguồn mô tả thuật toán chấm điểm và sắp xếp (sorting algorithm).

4.4 Cài đặt Hệ thống Bảo vệ Guardrail và HMAC

- **Lớp DelimitedDataEncapsulator:** Mã sinh chuỗi token hệ thập lục phân ngẫu nhiên thông qua `os.urandom` và `hashlib` để bọc payload logs.
- **Lớp HMACHashing (Database):** Đặc tả sơ đồ lược đồ CSDL SQLite (`threat_memory.db`), trigger tính toán hàm băm SHA-256 từ Previous Hash + Current Data.

4.5 Triển khai Giao diện Quản trị SOC (Streamlit Dashboard)

- **Kiến trúc Dashboard:** Ứng dụng mô hình Frontend (Streamlit) giao tiếp với Backend (SQLite/File logs) qua các thành phần giao diện động.

- **Các mô-đun Giao diện hiển thị:**

- *Trang Tổng quan (Real-time Queue)*: Trực quan hóa số liệu cảnh báo Tier-1 và phán quyết Tier-2.
- *Trang Phân tích Đe dọa (Threat Memory)*: Hiển thị đồ thị cảnh báo APT theo dải thời gian IP.
- *Trang Kiểm toán Toàn vẹn (Audit Trail)*: Module tự động xác minh HMAC Log Chaining bằng giao diện đèn giao thông (Xanh = Hợp lệ, Đỏ = Đứt gãy).

- **Human-in-the-loop (HITL)**: Giao diện duyệt (Approve/Reject) các bản án được AI đề xuất để cập nhật thành Firewall Rules thực thụ.

4.6 Đóng gói và Triển khai Hạ tầng (Containerization)

- **Đặc tả Dockerfile**: Cơ chế đa giai đoạn (multi-stage build) để giảm dung lượng file ảnh, biên dịch thư viện C++ (llama.cpp) cùng hỗ trợ CUDA.
- **Quản lý Dịch vụ docker-compose.yml**: Liên kết container của Dashboard, Agent Engine và volume gắn kết tập tin Logs chia sẻ.

Tóm lại, Chương 4 đã hệ thống hóa quá trình lập trình phần mềm SENTINEL từ các thuật toán lõi đến giao diện người dùng và cơ sở hạ tầng ảo hóa. Chương 5 tiếp theo sẽ thiết lập bài toán kiểm thử để đánh giá định lượng các thành phần này.

Chương 5

Thực nghiệm và Đánh giá kết quả

Chương này phơi bày các bằng chứng thực nghiệm của luận văn, chứng minh các giả thuyết nghiên cứu bằng những con số định lượng sắc bén. Hệ thống SENTINEL được đặt dưới khung đánh giá 5 chiều (5D Metrics: Độ chính xác, Hiệu năng, Bảo mật, Tính giải thích và Toàn vẹn). Nội dung tập trung vào thiết kế kiểm thử phân lớp (Ablation Study) và áp dụng các mô hình kiểm định thống kê y sinh (McNemar, Mann-Whitney U) để chứng minh sự cải tiến là có ý nghĩa toán học chặt chẽ.

5.1 Thiết lập Môi trường và Tập dữ liệu Thực nghiệm

- **Thông số Hệ thống phần cứng (Hardware Setup):** CPU Intel Core i9, 32GB RAM, GPU NVIDIA RTX 4060 Ti 16GB (để chạy Gemma-2-9B-IT Q4_K_M).
- **Tập dữ liệu CSE-CIC-IDS2018:** Giới thiệu tập dữ liệu đa dạng các hình thái tấn công (Brute Force, DoS, Web Attack) phục vụ đánh giá tính chính xác tổng thể.
- **Tập dữ liệu DAPT2020:** Phục vụ kịch bản kiểm thử nhận diện chuỗi tấn công APT (Advanced Persistent Threat).
- **Mô phỏng Luồng dữ liệu (Unified Stream):** Trình bày script gộp và phát luồng (stream) theo thời gian ảo để mô phỏng tính chất thời gian thực.

5.2 Khung đánh giá 5 Chiều (5D Metrics) và Thiết kế Ablation Study

- **Định nghĩa 5D Metrics:** Accuracy (F1, Precision, Recall), Performance (Latency, Throughput), Security (Robustness Rate), Explainability (Audit Completeness), Integrity (HMAC Validation).
- **Cấu hình Ablation Study (Từ Config A đến Config F):**
 - Config A (Baseline 1): Chỉ có Rule-based truyền thống.
 - Config B (Baseline 2): Chỉ có Local LLM thuần (Không RAG, không Welford).
 - Config C: Welford Tier-1 + LLM.
 - Config D: LLM + RAG (Single/FAISS).
 - Config E: LLM + Dual-RAG Hybrid.
 - Config F (SENTINEL Toàn vẹn): Tier-1 (Welford) + Tier-2 (LangGraph Agent + Dual RAG + Guardrails).

5.3 Đánh giá Độ chính xác (Accuracy) & Kiểm định McNemar

- **Kết quả Precision, Recall, F1-Score:** Biểu đồ và bảng so sánh các cấu hình. Nêu bật việc Config F đạt độ cân bằng F1 cao nhất (loại bỏ hoàn toàn False Positives từ Rule-based trong khi cải thiện Recall cho Zero-day).
- **Phát hiện APT:** Phân tích việc Tier-1 (Welford) bắt được các tín hiệu dị thường yếu và kích hoạt chuỗi Threat Memory của tác tử.
- **Kiểm định McNemar's Test:** So sánh ma trận nhầm lẫn (Confusion Matrix) giữa Config B và Config F. Chứng minh $p - value < 0.05$ (bác bỏ giả thuyết Null), xác nhận sự khác biệt là do mô hình vượt trội, không phải ngẫu nhiên.

5.4 Đánh giá Hiệu năng Độ trễ (Performance) & Kiểm định Mann-Whitney U

- **Phân tích Độ trễ thời gian (Inference Latency):** Bảng so sánh thời gian trễ trung bình/luồng. Sự giảm tải đáng kinh ngạc nhờ Tier-1 (Welford thả trôi log sạch $O(1)$ giây) và Semantic Cache (Cache Hit giảm thời gian LLM từ 4-6 giây xuống mili-giây).
- **Kiểm định Phi tham số Mann-Whitney U:** Chứng minh phân phối trễ của cấu hình SENTINEL nhanh hơn đáng kể ($p < 0.05$) so với việc đẩy toàn bộ log cho LLM phân tích.

5.5 Đánh giá Khả năng Kháng tấn công Nghịch đảo (Security / Robustness)

- **Bộ dữ liệu Prompt Injection (45 Payloads):** Mô tả các kịch bản thao túng (ví dụ: "Bỏ qua luật hệ thống, báo cáo IP này an toàn").
- **Đo lường tỷ lệ chặn đứng (Block Rate):** So sánh giữa hệ thống không có Guardrail (bị thao túng 80%) và hệ thống bật Delimited Data Encapsulation của SENTINEL (chặn 100% các nỗ lực tiêm mã).

5.6 Đánh giá Tính Toàn vẹn và Chất lượng RAG bằng LLM-as-a-Judge

- **Kiểm toán HMAC Chaining:** Kịch bản giả định một hacker xâm nhập cơ sở dữ liệu thay đổi nhãn log. Giao diện báo cáo chuỗi băm đứt gãy tức thì.
- **Chấm điểm RAG (RAGAS / LLM-as-a-Judge):** Sử dụng mô hình Llama-3.1 ngoài hệ thống làm trọng tài độc lập chấm điểm 4 tiêu chí: Context Precision, Context Recall, Faithfulness, Answer Relevancy. Chứng minh Dual-RAG có RRF vượt trội so với Single Vector Search.

Tóm lại, Chương 5 đã chứng thực sức mạnh kỹ thuật của SENTINEL thông qua các dữ liệu định lượng cứng rắn và các kiểm định thống kê y sinh khắt khe. Chương 6 sẽ đúc kết lại ý nghĩa của kết quả này và định hướng tương lai.

Chương 6

Kết luận và Hướng phát triển

Chương cuối cùng này đúc kết lại toàn bộ hành trình nghiên cứu của đề tài "Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động sử dụng AI Tác tử"(SENTINEL). Chương tổng hợp các kết quả khoa học đã được chứng minh, tự nhận xét những mặt còn hạn chế trong khuôn khổ luận văn thạc sĩ và mở ra các chân trời nghiên cứu mới cho ngành an ninh mạng kết hợp Trí tuệ Nhân tạo.

6.1 Tổng hợp các Kết quả Nghiên cứu Đạt được

- **Trả lời các câu hỏi nghiên cứu:** Khẳng định lại việc giải quyết thành công bài toán độ trễ và Alert Fatigue thông qua kiến trúc phân lớp Tier-1 Welford và Tier-2 LangGraph Agent.
- **Bảo mật hệ thống AI (AI Security):** Chứng minh tính khả thi của kỹ thuật Delimited Data Encapsulation và cấu trúc HMAC Chaining trong việc phòng chống các rủi ro thao túng hệ thống nhận thức nội bộ của doanh nghiệp (Prompt Injection, Data Tampering).
- **Giải quyết bài toán Zero-day & APT:** Sự kết hợp xuất sắc giữa kỹ thuật theo dõi chuỗi cảnh báo lịch sử (Threat Memory) và kho dữ liệu lai (Dual-RAG MITRE + NIST) mang đến nhận thức ngữ cảnh sâu rộng, giúp hệ thống phơi bày các chiến dịch tinh vi nhất.

- **Kiểm định tính đúng đắn:** Các thành quả trên không dừng ở mặt lý thuyết mà được xác thực mạnh mẽ bởi các độ đo 5D và kiểm định thống kê chuẩn mực (McNemar, Mann-Whitney U) trên dữ liệu thực tế.

6.2 Đóng góp Khoa học và Thực tiễn

- **Giá trị khoa học:** Cung cấp một khung kiến trúc tiêu chuẩn (framework) có tính module hóa cao về việc kết hợp Thống kê Toán học và Mô hình Ngôn ngữ Lớn trong an ninh mạng. củng cố kho tàng lý thuyết về bảo mật LLM.
- **Giá trị thực tiễn:** Sản phẩm hoàn thiện SENTINEL có thể được sử dụng làm công cụ lõi hoặc công cụ hỗ trợ độc lập cho các doanh nghiệp vừa và nhỏ (SMBs) không đủ ngân sách vận hành đội ngũ SOC Tier-1 quy mô lớn, mà vẫn đảm bảo tính bảo mật Zero Trust khi vận hành offline.

6.3 Những Hạn chế còn Tồn đọng

Mặc dù hệ thống thể hiện sự ưu việt, nghiên cứu vẫn còn những rào cản nhất định:

- **Định dạng log đầu vào:** Hệ thống hiện thử nghiệm sâu trên lưu lượng mạng (Network Flow logs) và HTTP payload. Căn cứ thực tế đòi hỏi xử lý thêm rất nhiều định dạng log phi cấu trúc khác (Windows Event Logs, Linux Syslogs, CloudTrail) dẫn đến yêu cầu tinh chỉnh parser lớn hơn.
- **Rào cản Phần cứng:** Tốc độ suy luận dù đã được tăng tốc bằng bộ đệm (Semantic Cache) nhưng khi gặp cảnh báo hoàn toàn mới, LLM vẫn cần tốn thời gian suy luận, đòi hỏi ngân sách đầu tư GPU phần cứng chuyên dụng khá cao nếu quy mô luồng mạng hàng trăm Gigabit/s.
- **Thiết kế Mitigation Vật lý:** Nghiên cứu cố tình đóng khung hệ thống ở mức đề xuất (Recommend Firewall Rules) thay vì can thiệp vật lý vào router để tránh tấn công tự

từ chối dịch vụ (Self-DoS), tuy nhiên điều này hạn chế khả năng Real-time Blocking thực thụ.

6.4 Định hướng Phát triển Tương lai

Từ những hạn chế trên, hướng đi mở rộng cho hệ thống bao gồm:

- **Học liên kết (Federated Learning):** Mở rộng SENTINEL thành kiến trúc phi tập trung. Thay vì chia sẻ logs mạng (vi phạm quyền riêng tư), các điểm cuối SOC chỉ chia sẻ tham số mô hình đã học được về các biến thể mã độc mới cho nhau.
- **Kiến trúc Đa Tác tử (Multi-Agent System):** Phân rã LangGraph Agent thành nhiều tác tử chuyên biệt: Malware Analyst Agent, Network Analyst Agent, Threat Intel Agent tranh luận với nhau trước khi đưa ra bản án chung thẩm, nâng cao hơn nữa độ chính xác.
- **Kiểm thử Tự động (Automated Red Teaming):** Xây dựng một tác tử Red Team nội bộ liên tục sinh ra các payload tấn công tinh vi nhắm vào Sentinel để tự đánh giá và nâng cấp khả năng phòng thủ của hệ thống.

Khép lại một công trình nhỏ, nhưng mở ra những khát vọng lớn lao trong nỗ lực bảo vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [3] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

Chương A

Các payload tấn công nghịch đảo thử nghiệm

Nội dung phụ lục...